

Security Analysis Report

eMagiz Ticketing System - Team 04

Executive Summary

This report analyzes the security aspects of the eMagiz Ticketing System. The system implements basic security measures including authentication, authorization, and data protection, but contains several vulnerabilities that should be addressed.

Security Controls Implemented

Authentication

- Token-based authentication with UUID tokens
- AuthFilter validates tokens for protected endpoints
- Public endpoints: login and password reset
- Token expiration: 24 hours for auth tokens, 30 minutes for reset tokens

Authorization

- Role-based access control (Admin/User)
- All API endpoints require authentication except public routes
- User ID stored in request context for authorization decisions

Data Protection

- Password hashing using bcrypt with salt
- Tokens stored in database
- Passwords nullified in User objects after saving

Input Validation

- Basic null/empty checks for login
- JSON parsing for REST endpoints
- Path parameter validation by JAX-RS

Security Vulnerabilities Identified

Medium Severity

1. Missing Rate Limiting

- Location: Login and password reset endpoints
- Issue: No protection against brute force attacks
- Recommendation: Implement IP/username-based rate limiting

2. Token Transmission Security

- Issue: No HTTPS enforcement for token transmission
- Recommendation: Enforce HTTPS, implement HSTS header

3. Missing Logging and Monitoring

- Issue: Limited security-relevant logging
- Recommendation: Implement comprehensive logging for security events

Low Severity

1. User Enumeration Vulnerability

- Location: Password reset endpoint
- Issue: Potential timing differences in email lookup
- Recommendation: Ensure constant-time database operations

2. Insufficient Password Policy

- Location: User creation endpoint
- Issue: No password complexity requirements
- Recommendation: Implement password policy validation

3. Missing Secure Headers

- Issue: Absence of HSTS, CSP, X-Frame-Options, etc.
- Recommendation: Implement security header filter

4. Session Management Issues

- Issue: Tokens valid until expiration regardless of password changes
- Recommendation: Implement token invalidation on password change

Informational

1. Database Connection Exposure

- Issue: Potential information leakage through error messages
- Recommendation: Improve error handling, use environment variables

Compliance with User Story Security Requirements

Based on requirements from reqs.txt:

- User Creation (with password hashing)
- Unique Identity (unique username constraint)
- Action Logging (requires verification of implementation)
- Role-Based Access (roles stored and assignable)

- Ticket Validation (requires verification)
- Ticket Assignment System (implemented)

Risk Assessment Summary

Risk Level	Count	Issues
High	0	None identified
Medium	3	Missing rate limiting, token transmission security, missing logging
Low	4	User enumeration, insufficient password policy, missing secure headers, session management
Informational	1	Database connection exposure

Recommendations

Immediate Actions

1. Implement rate limiting on authentication endpoints
2. Add security headers to HTTP responses
3. Improve error handling to prevent information leakage
4. Ensure password validation during user creation

Medium-term Actions

1. Implement comprehensive security logging
2. Review and improve session management (token invalidation on password change)
3. Conduct penetration testing
4. Implement proper input validation for all endpoints

Long-term Actions

1. Establish security testing in CI/CD pipeline
2. Regular security audits and code reviews
3. Consider WAF for production deployment
4. Security training for development team

Conclusion

The eMagiz Ticketing System implements appropriate foundational security controls for an

academic project. However, to be production-ready, the identified vulnerabilities must be addressed. The system shows good practices in password hashing and token-based authentication but lacks essential security controls found in production systems.

Addressing these recommendations would significantly improve the system's security posture and prepare it for real-world deployment.